

ZENA Healthcare Identity Investigation Report

Prepared for: Priya Nair, SOC Manager | Date: 20 August 2026 | Classification: OFFICIAL-SENSITIVE

1. Executive Summary

The clinical administrator account j.okeefe was compromised on the evening of 9 June via an MFA-fatigue attack, in which an attacker used previously stolen credentials to trigger repeated authentication prompts until one was mistakenly approved. Within hours, the same attacker infrastructure was used to escalate a service account, SVC-epr-sync, to Helpdesk Administrator, a privilege it should never hold. This is not an isolated account issue: the attacker's IP address matches infrastructure already identified in the compromised imaging workstation (IMG-WS-07), confirming one coordinated attack, not several unrelated incidents. A second flagged account, a.shah, was investigated with equal rigor and is confirmed as a genuine holiday sign-in, already reviewed and dismissed by our systems.

2. Timeline

At 21:55 on 9 June, j.okeefe signed in legitimately from Manchester, the last known-good activity on the account. Between 22:03 and 22:39, the account was hit with nine consecutive MFA denials from an IP address in Rotterdam, Netherlands, a classic MFA-fatigue (push-bombing) pattern. At 22:41, one prompt was mistakenly approved, and the attacker gained access from that same Rotterdam IP. From there, the compromised account accessed the Electronic Patient Records system at 02:17 on 10 June, and by 02:50 had routed a further sign-in through an anonymising proxy, a deliberate evasion step. The following day, at 01:08 on 11 June, the service account SVC-epr-sync, which normally authenticates only via certificate for automated syncing, showed an abnormal interactive sign-in from the same Rotterdam IP. Four minutes later, at 01:12, that service account was granted the Helpdesk Administrator role.

Quantified proof of compromise: The gap between the legitimate Manchester sign-in and the Rotterdam sign-in was 46 minutes. The distance between these locations (~600km) cannot be travelled by any means at that time. This is not a flagged anomaly, it is a mathematical impossibility, confirming the credential was used by someone other than j.okeefe.

3. Risk Assessment

The MFA fatigue attack succeeded because the attacker already held valid credentials likely obtained through earlier phishing activity identified in our alert backlog and defeated the second factor through persistence rather than any technical bypass. This points to a human-layer control gap, not a technology failure. Privilege escalation followed within 26 hours of the initial compromise, with the attacker moving from one compromised identity to escalating a service account's privileges, indicating deliberate lateral movement rather than opportunistic access. The risk to patient data is real: the compromised account accessed EPR directly, meaning special-category health data was potentially exposed, which carries UK GDPR/ICO implications requiring DPO review. Critically, the attacker's IP (45.137.21.88) links this identity compromise directly to the previously identified workstation intrusion, indicating an active, multi-stage campaign still in progress across both endpoint and identity layers.

4. Affected Users

Two accounts are confirmed compromised: j.okeefe, based on the MFA-fatigue pattern, the quantified 46-minute impossible-travel gap, a run of high-risk sign-ins, and direct EPR access from the attacker's IP; and SVC-epr-sync, based on its abnormal authentication method, the same attacker IP, and an unauthorized privilege escalation. A third account, a.shah, was investigated with the same rigor and is confirmed clean, a single sign-in from Spain that was already flagged and dismissed by our systems as low risk, with normal MFA satisfaction and no follow-on suspicious activity, consistent with genuine annual leave.

5. Recommendations

Immediately, we should force a password reset and revoke all active sessions for both j.okeefe and SVC-epr-sync, and remove the Helpdesk Administrator role from SVC-epr-sync while auditing every action taken under that role since 11 June. As an urgent next step, Marcus Webb (DPO) should be engaged to assess our ICO 72-hour notification obligations, given confirmed EPR access. In the short term, we recommend enforcing number-matching MFA rather than simple approve/deny prompts to prevent future fatigue attacks, and investigating whether the IP address 45.137.21.88 has touched any other accounts or systems beyond those identified in this report.